

Threat Analysis Report

รายงานวิเคราะห์แคมเปญการโจมตี Citrix NetScaler gateway โดยใช้ช่องโหว่ CitrixBleed 2 และ DragonForce Ransomware

13/7/2026

TLP:CLEAR





สารบัญ

สารบัญ.....	2
บทสรุปสำหรับผู้บริหาร.....	3
Threat Actor Profiles	4
การวิเคราะห์เชิงเทคนิค.....	5
Tactics, Techniques, and Procedures (MITRE ATT&CK)	13
Indicators of Compromise (IoCs)	15
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ	18
อ้างอิง (References).....	22



บทสรุปสำหรับผู้บริหาร

รายงานฉบับนี้เป็นการวิเคราะห์แคมเปญการโจมตีที่ใช้ประโยชน์จากช่องโหว่ **CVE-2025-5777 (CitrixBleed 2)** บนอุปกรณ์ Citrix NetScaler Gateway/ADC ที่เปิดเผยสู่อินเทอร์เน็ต เพื่อขโมย Session token ของผู้ใช้งานที่ต้องผ่านช่องโหว่ประเภท Memory overread และนำไปสู่การเข้ายึกระบบขั้นสูงสุดด้วย Ransomware จากกลุ่ม **DragonForce** ซึ่งเป็นกลุ่มที่ดำเนินการในรูปแบบ Ransomware-as-a-Service (RaaS) และได้พัฒนาสู่โมเดล "Cartel" ที่เปิดให้ผู้ไม่หวังดีรายอื่นเช่าใช้โครงสร้างพื้นฐานภายใต้แบรนด์ของตนเอง ปัจจุบันมีเหยื่อที่ถูกกระบุบน Data leak site ของกลุ่มแล้วมากถึง 593 ราย

การโจมตีมีลักษณะเป็นขั้นตอนต่อเนื่องที่ซับซ้อนและรวดเร็ว เริ่มจากการขโมย Session โดยไม่ต้องผ่าน MFA ตามด้วยการยกระดับสิทธิ์เป็น SYSTEM ผ่านการปลอมแปลง Registry symbolic link เพื่อ hijack การทำงานของ Windows Service (AppMgmt) จากนั้นสร้างบัญชีผู้ดูแลระบบสำรอง (เช่น ctxsvc, CtxAppVCOMService) และติดตั้งเครื่องมือ Remote Access ที่ถูกต้องตามกฎหมาย (ScreenConnect, Zoho Assist, Netbird, Atera) เพื่อคงการเข้าถึงโดยหลบเลี่ยงการตรวจจับ ก่อนขยายผลไปยัง Domain Controller ด้วย Impacket และดึง Credential ด้วย Mimikatz ในบางเหตุการณ์ ระยะเวลาตั้งแต่เข้าถึงระบบครั้งแรกจนถึงขั้นตอนเข้ารหัสไฟล์ใช้เวลาไม่ถึง 1 ชั่วโมง

ผลกระทบที่เกิดขึ้นครอบคลุมทั้งการเข้าถึงระบบโดยไม่ได้รับอนุญาต การขโมยข้อมูลสำคัญ ออกนอกองค์กร (Double Extortion) และการเข้ารหัสไฟล์เพื่อเรียกค่าไถ่ โดย DragonForce จะทำลายกลไกกู้คืนระบบทั้งหมด (Shadow Copy, System State Backup, Boot Recovery) ก่อนเข้ารหัสเสมอ ทำให้การกู้คืนผ่านกลไกมาตรฐานของ Windows นั้นแทบเป็นไปไม่ได้

องค์กรควรเร่งดำเนินการแพตช์ช่องโหว่ CVE-2025-5777 โดยทันที พร้อม Terminate session ที่ค้างอยู่ทั้งหมดหลังแพตช์ เนื่องจาก Session token ที่ถูกขโมยไว้ก่อนหน้านี้ยังคงใช้งานได้ แม้ปิดช่องโหว่แล้ว รวมถึงเฝ้าระวังสัญญาณตาม IoCs และพฤติกรรมที่ระบุไว้ในรายงานฉบับนี้อย่างใกล้ชิด และจัดเตรียม backup แบบ offline/immutable ที่แยกออกจากเครือข่ายหลักโดยสมบูรณ์ เป็นมาตรการป้องกันที่จำเป็น



Threat Actor Profiles



DragonForce เป็นกลุ่ม Ransomware Group ที่มีการดำเนินการในลักษณะของ Ransomware-as-a-Service ที่มีจุดประสงค์ทางการเงิน พบการดำเนินการ Ransomware ครั้งแรกในช่วงปลายปี 2023 โดยโจมตีเหยื่อแบบ Double extortion อย่างต่อเนื่องจนมาถึงช่วงปัจจุบัน รวมแล้วมีเหยื่อที่ถูกระบุไว้ที่หน้า Data leak site ของกลุ่มมากถึง 593 ราย ณ วันที่ 21 กรกฎาคม 2024 อีกทั้งกลุ่มนี้ยังเป็นกลุ่มที่มีเทคนิคในการเข้าโจมตีที่หลากหลาย อย่างเช่น BYOVD (bring your own vulnerable driver), Shadow copy removal และ Initial access broker

จุดเปลี่ยนสำคัญของกลุ่ม DragonForce คือการปรับเปลี่ยนจาก RaaS ไปเป็น Cartel Ransomware ในช่วงมีนาคม 2024 ซึ่งเปิดให้กลุ่มผู้ไม่หวังดีอื่น ๆ สามารถปฏิบัติการภายใต้ชื่อแบรนด์ของตัวเองแต่ใช้งานโครงสร้างพื้นฐาน เครื่องมือ และบริการต่างๆ ของการโจมตีเป็นของกลุ่ม DragonForce โดยผู้เข้าร่วมจะได้รับค่าตอบแทนสูงถึง 80% ของค่าไถ่ พร้อมสิทธิ์ในการปรับแต่ง Ransomware ให้เข้ากับเหยื่อที่ต้องการ จัดการช่องทางการติดต่อ C2 ด้วยตนเอง นอกจากนี้ทาง DragonForce ยังมีบริการช่วยเหลือพันธมิตร เช่น Technical Support ช่วยในการโปรโมทต่าง ๆ รวมไปถึงการช่วยถอดรหัสลับที่ได้จากเหยื่อ

ต่อมาในเดือนตุลาคม 2024 กลุ่มได้ปรับปรุงกระบวนการรับสมัครพันธมิตรอีกครั้ง โดยยกเลิกการตรวจสอบประวัติ (vetting) และค่ามัดจำเดิมที่เคยสูงถึง \$10,000 เปลี่ยนเป็นค่าลงทะเบียนคงที่เพียง \$500 ผ่านสกุลเงิน XMR หรือ BTC เพื่อเปิดรับพันธมิตรในวงกว้างขึ้น พร้อมเปิดตัวโมเดล "build-your-own-team" ที่อนุญาตให้พันธมิตรหลักสามารถดูแลและบริหาร sub-affiliate ได้สูงสุด 2 ราย ทำให้เกิดโครงสร้างแบบ multi-tier ที่ช่วยขยายเครือข่ายการโจมตีได้รวดเร็วยิ่งขึ้น



การยืนยันตัวตนหลายชั้น จุดสังเกตที่ทำให้ทราบว่าเป็นการโจมตีแบบ Session Hijack นั้นคือการที่ไม่พบ log ของการ Authenticate จาก IP ของผู้ไม่หวังดีเลย

3. **Privilege Escalation:** เนื่องจาก session ที่ถูกขโมยไปนั้นเป็นสิทธิ์ของพนักงานทั่วไป ผู้ไม่หวังดีจึงต้องยกระดับสิทธิ์ผ่านการใช้ชุดเครื่องมือ LPE Tool ซึ่งเป็นไฟล์ executable โดยวางไว้ที่ C:\temp\ หรือ C:\logs\ โดยไฟล์ที่ถูกวางมักเป็น Archive ที่ติดรหัสผ่าน และผ่านการดาวน์โหลดจาก temp[.]sh กลไกการทำงานของเครื่องมือมี 4 ขั้นตอนดังนี้
 - a. เครื่องมือสร้าง Registry Key ประเภท REG_LINK (Symbolic Link) ไว้ในไดเรกทอรีหรือตำแหน่งที่บัญชีผู้ใช้ทั่วไปมีสิทธิ์ในการแก้ไข (Write Access) จากนั้นกำหนดค่าของ Link ดังกล่าวให้ชี้เป้าหมาย (Redirect) ไปยัง Protected Key ที่ต้องการจะแก้ไข ซึ่งตามปกติแล้วผู้ใช้ทั่วไปจะไม่มีสิทธิ์เข้าถึงหรือปรับเปลี่ยนได้
 - b. เรียกใช้งานคำสั่ง “gpupdate” เพื่อบังคับให้ Group Policy (GP) Engine เริ่มกระบวนการทำงานและประมวลผลนโยบายของเครื่อง (Machine Policy) ใหม่
 - c. เรียกใช้งาน “sc start AppMgmt” เพื่อให้ Service Control Manager เรียกใช้ config ที่ถูกเขียนใหม่ในบริบทสิทธิ์สูง และเป็นการ Relaunch เครื่องมือใหม่ในฐานะ SYSTEM
 - d. ก่อนที่จะดำเนินการขั้นตอนที่ 3 เครื่องมือจะบันทึก Registry tree เอาไว้ก่อนและคืนค่าเดิมหลังจากเสร็จสิ้นกระบวนการ ทำให้ Registry ดูเหมือนกับตอนที่ยังไม่ถูกโจมตีและยังเป็นการลบ Artifact จากการโจมตีอีกด้วย
4. **Persistence:** หลังจากที่เราเรียกใช้งาน LPE Tools ในสิทธิ์ System ได้สำเร็จ ผู้ไม่หวังดีได้ทำการสร้าง Local Admin ด้วยคำสั่งที่เหมือนกันในทุกเหตุการณ์ `net user <ctx-account> <hardcoded-password> /add /y และ net localgroup Administrators <ctx-account> /add` โดยบัญชีที่ถูกสร้างนั้นจะใช้ Username ที่ถูกกลมกลืนกับสภาพแวดล้อมของ Citrix เช่น ctxsvc, CtxAppVCOMService, หรือ test เพื่อให้ผู้ดูแลระบบที่ไล่ดูรายชื่อบัญชีอย่างผิวเผินไม่สงสัย และรหัสผ่านนั้นจะเป็นค่า Hardcoded ในตัวเครื่องมือ ไม่ใช่การสุ่มใหม่เหยื่อต่อเหยื่อ การดำเนินการนี้เป็นเหมือนทางเข้าสำรองเพื่อที่จะไม่ต้องพึ่งพา session ที่ขโมยมา และการดำเนินการสร้างการคงอยู่ในอีกรูปแบบหนึ่งคือการใช้งานเครื่องมือ Remote Access โดยใช้งานเครื่องมือ Remote ที่ถูกต้องเพื่อการถูกตรวจจับที่ยากขึ้น อย่างเช่น ScreenConnect, Zoho Assist, Netbird และ Atera

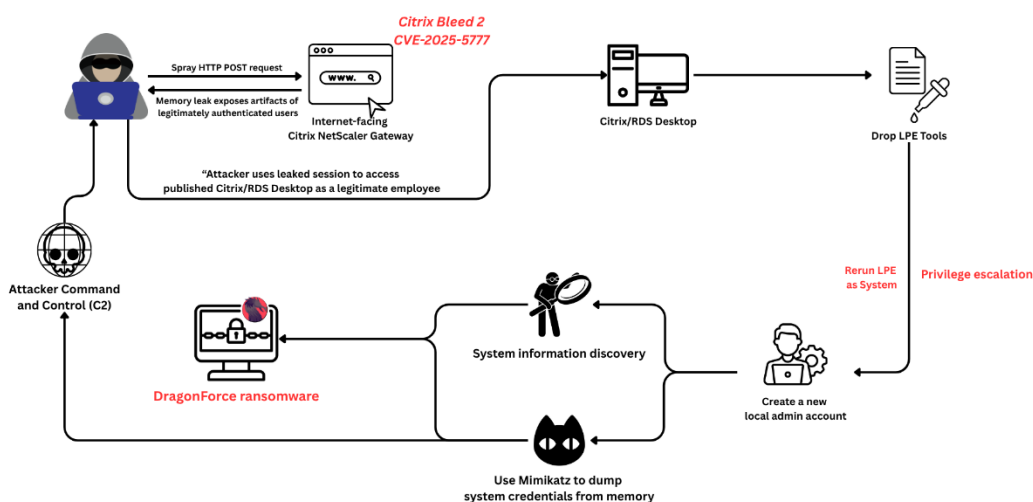


5. Lateral movement and Credential dump: หลังจากการดำเนินการต่าง ๆ ข้างต้น

ผู้ไม่หวังดีได้ดำเนินการอื่น ๆ เพื่อขยายขอบเขตการโจมตีไปยังระบบอื่น

- ทำการ RDP กลับเข้ามายังระบบโดยใช้งานบัญชี admin ที่ได้สร้างใหม่เพื่อดำเนินการต่อแบบ hands-on-keyboard แทนการใช้เครื่องมือ
- ใช้งาน PsExec ด้วย flag -s กับโฮสต์ภายในเพื่อขอ shell ในบริบท SYSTEM บนเครื่องเป้าหมายถัดไป ซึ่งเป็นวิธีมาตรฐานในการขยายสิทธิ์ข้ามเครื่อง
- การสำรวจ session และระบบ โดยใช้คำสั่งพื้นฐานของ Windows เช่น qwinsta (ดู session ที่ล็อกอินอยู่), whoami, wmic เพื่อสำรวจว่าใครอยู่ในระบบและระบบมีโครงสร้างอย่างไร ก่อนตัดสินใจเคลื่อนที่ต่อ
- ใช้งาน Impacket โจมตีใส่ Domain Controller ผู้ไม่หวังดีครอบครองเครื่องมือชุด Impacket ซึ่งจะครอบงำในรีโมตสไตล์ RemCom (remote command execution ผ่าน SMB) เพื่อรับคำสั่งจากระยะไกลบน DC ในหนึ่งเคส Microsoft Defender ตรวจจับ payload การรับคำสั่งระยะไกลของ Impacket และกิจกรรม dump registry ได้สำเร็จ
- Mimikatz ผู้ไม่หวังดีเรียกใช้งานสำหรับ dump credential โดยพบการรันจากไคลเอนต์ที่ผิดปกติ เช่น C:\Binaries เพื่อดึง credential ที่แคชไว้ในหน่วยความจำ ซึ่งมักเป็นขั้นตอนก่อนการเข้าถึงบัญชีระดับ domain admin หรือการแพร่กระจายไปทั่วองค์กร

6. Ransomware หลังจากผู้ไม่หวังดีสามารถที่จะยึดและสร้างบัญชีผู้ดูแลระบบของเหยื่อได้สำเร็จแล้ว ผู้ไม่หวังดีจะครอบครองและเรียกใช้งาน DragonForce Ransomware (1.exe)



ภาพแผนภาพการโจมตี



DragonForce Ransomware

ระบบที่รองรับ: ESXi, Linux, BSD, NAS (esxi, linux_arm_x86, linux_arm_x86_64, linux_x86, linux_x86_64, freebsd_arm_x86_64, freebsd_x86, freebsd_x86_64)

เนื่องจาก DragonForce ดำเนินการในรูปแบบ Ransomware-as-a-Service (RaaS) ที่เปิดให้ affiliate สามารถปรับแต่ง binary ได้เอง (เช่น กำหนด encryption parameter, นามสกุลไฟล์ที่ต่อท้าย, และเนื้อหา ransom note) จึงพบรูปแบบที่มีความหลากหลายค่อนข้างมากในแต่ละเหตุการณ์ อย่างไรก็ตาม จากการติดตามของหลายหน่วยงานพบว่าโค้ดพื้นฐาน (codebase) ของ DragonForce มีที่มาจากเครื่องมือของกลุ่มแรนซัมแวร์อื่นที่หลุดรั่วออกมา ไม่ใช่การพัฒนาขึ้นเองทั้งหมด โดยมีวิวัฒนาการ 2 ช่วงหลัก

สิงหาคม 2023: เริ่มปฏิบัติการด้วย builder ของ LockBit 3.0 ที่หลุดรั่วออกสู่สาธารณะ

กรกฎาคม 2024: ปลอ่ยตัวแปรใหม่ที่มีรายงานว่าอิงพื้นฐานจาก Conti Ransomware V3

การใช้ leaked builder จากทั้งสองตระกูลนี้สอดคล้องกับข้อสันนิษฐานว่า Affiliate ของ DragonForce บางส่วนอาจมีความเชื่อมโยงกับกลุ่มของ LockBit และ Conti มาก่อน และยังอธิบายได้ว่าเหตุใดจึงพบพฤติกรรมของ binary ที่แตกต่างกันไปในแต่ละเหตุการณ์ เพราะอาจเป็นคนละ payload ที่สร้างจาก builder คนละรุ่น ไม่ใช่ signature เดียวที่คงที่



กลไกป้องกันการกู้คืนระบบ (Anti-Recovery)

ก่อนจะดำเนินการเข้ารหัสไฟล์ DragonForce จะทำลายกลไกกู้คืนของระบบก่อนเสมอ เพื่อปิดทางไม่ให้เหยื่อกู้คืนข้อมูลได้ด้วยตัวเองแม้จะไม่จ่ายค่าไถ่

- ลบ Volume Shadow Copy ทั้งหมด (vssadmin delete shadows /all /quiet)
- ลบ System State Backup (wbadmin delete systemstatebackup)
- ตั้งค่า Recovery Enabled เป็น No ผ่าน bcdedit /set {default} recoveryenabled No ปิดกั้นการกู้คืนตอน boot
- ลบ backup catalog เพิ่มเติมด้วย wmic delete catalog -quiet เพื่อทำลาย metadata ของชุดสำรองข้อมูลที่อาจหลงเหลืออยู่

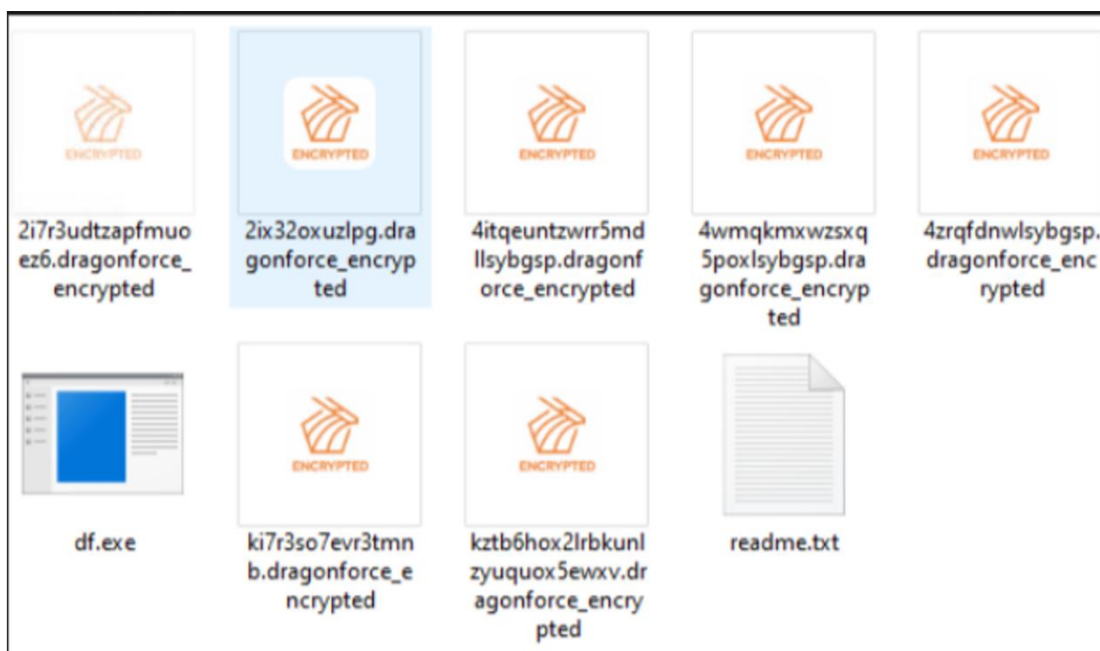
การดำเนินการชุดนี้ ครอบคลุมทั้งระดับไฟล์ (shadow copy), ระดับระบบ (system state backup) และระดับ boot-time recovery พร้อมกัน ทำให้การกู้คืนผ่านกลไก built-in ของ Windows แทบเป็นไปไม่ได้ และเป็นเหตุผลที่ **backup แบบ offline/immutable ที่แยกออกจากระบบโดยสมบูรณ์** ยังคงเป็นมาตรการป้องกันที่จำเป็น ไม่สามารถพึ่งพา shadow copy หรือ built-in backup ของ Windows เพียงอย่างเดียวได้

นามสกุลไฟล์ที่ถูกเข้ารหัส (File Extension)

ด้วยความที่เป็น RaaS ที่ปรับแต่งได้ต่อ affiliate นามสกุลไฟล์ที่พบจึงไม่คงที่ตายตัว แต่รูปแบบที่พบและได้รับการยืนยันชัดเจนที่สุดคือ

{ชื่อไฟล์เดิม/อักขระสุ่ม}.dragonforce_encrypted

นอกจากนี้ยังมีรายงานพบตัวแปรที่ใช้รูปแบบอื่น เช่น .locked ต่อท้ายนามสกุลเดิม ({filename}.{original_ext}.locked) ซึ่งบ่งบอกว่าไม่ควรยึดนามสกุลใดนามสกุลหนึ่งเป็นตัวชี้วัดหลัก แต่ควรตรวจสอบพฤติกรรมประกอบอื่น เช่น การลบ shadow copy, การมี ransom note, และ process ที่เกี่ยวข้อง เพื่อยืนยันว่าเป็นการโจมตีจาก DragonForce จริง



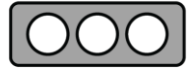
ภาพไฟล์บนระบบเหยื่อที่ถูกเข้ารหัส

Ransom Note

Ransom note ของ DragonForce พบได้หลายรูปแบบชื่อไฟล์ตามแต่รูปแบบที่ affiliate เลือกใช้ เช่น readme.txt, Contact Us.txt และ {อักขระสุ่ม}.readme.txt โดยเนื้อหาภายในมีโครงสร้างสอดคล้องกับ ransom note ทั่วไปของ RaaS สายพันธุ์ LockBit/Conti คือ

- ระบุว่าข้อมูลถูกเข้ารหัสและขโมยออกไปแล้ว (สอดคล้องกับกลยุทธ์ double extortion)
- แจ้งช่องทางการติดต่อผ่าน Tox (โปรโตคอลแชทเข้ารหัสแบบ peer-to-peer ที่กลุ่ม ransomware หลายรายนิยมใช้เพราะยากต่อการติดตามตัว)
- ข่มขู่กำหนดเวลา (deadline) หากเหยื่อไม่ติดต่อเจรจาหรือจ่ายค่าไถ่ภายในระยะเวลาที่กำหนด จะทำการเผยแพร่ข้อมูลที่ขโมยไปสู่สาธารณะผ่าน leak site ของกลุ่ม

นอกจากไฟล์ข้อความแล้ว DragonForce ยังมีพฤติกรรมเสริมเพื่อสร้างแรงกดดันทางจิตวิทยาให้เหยื่อรับรู้การโจมตีในหลายช่องทางพร้อมกัน ได้แก่ การเปลี่ยนภาพพื้นหลังเดสก์ท็อป (wallpaper) เป็นข้อความแจ้งเตือน และในบางตัวแปรมีการส่งพิมพ์ ransom note ออกทางเครื่องพิมพ์ที่เชื่อมต่อกับระบบเครือข่ายโดยตรง เพื่อให้ข้อความไปปรากฏในพื้นที่ทำงานจริงของเหยื่อ ไม่ใช่แค่บนหน้าจอคอมพิวเตอร์



EUPICgetREADME.txt - Notepad
File Edit Format View Help
Hello!

Your files have been stolen from your network and encrypted with a strong algorithm. We work for money and are not associated with politics. All you need to do is contact us and pay.

--- Our communication process:

1. You contact us.
2. We send you a list of files that were stolen.
3. We decrypt 1 file to confirm that our decryptor works.
4. We agree on the amount, which must be paid using BTC.
5. We delete your files, we give you a decryptor.
6. We give you a detailed report on how we compromised your company, and recommendations on how to avoid such situations in the future.

--- Client area (use this site to contact us):

Link for Tor Browser: [http://\[redacted\].onion](http://[redacted].onion)
>>> Use this ID: [redacted] to begin the recovery process.

* In order to access the site, you will need Tor Browser,
you can download it from this link: <https://www.torproject.org/>

--- Additional contacts:

Support Tox: [redacted]

--- Recommendations:

DO NOT RESET OR SHUTDOWN - files may be damaged.
DO NOT RENAME OR MOVE the encrypted and readme files.
DO NOT DELETE readme files.

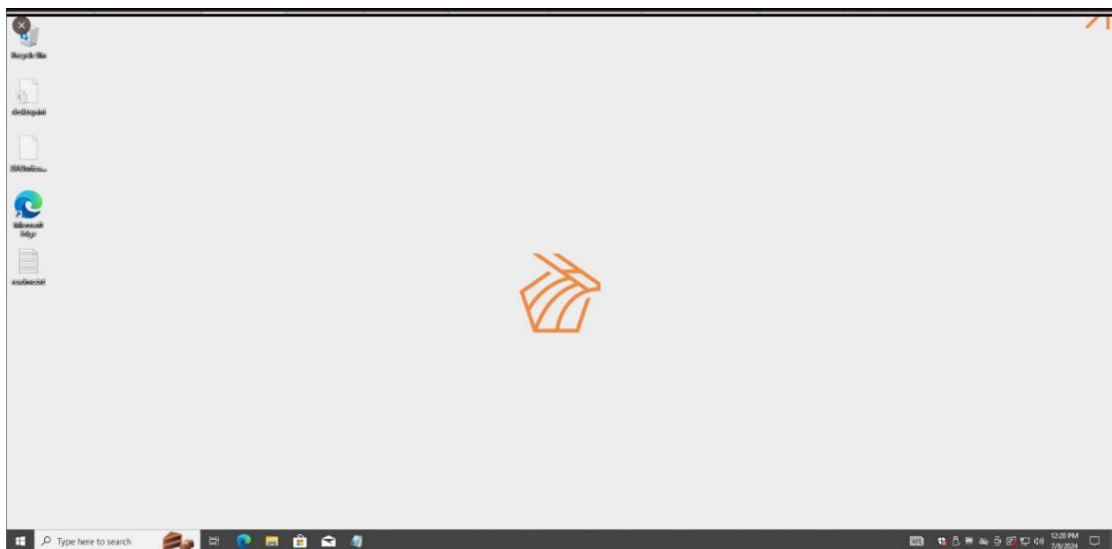
--- Important:

If you refuse to pay or do not get in touch with us, we start publishing your files.
26/04/2024 00:00 UTC the decryptor will be destroyed and the files will be published on our blog.

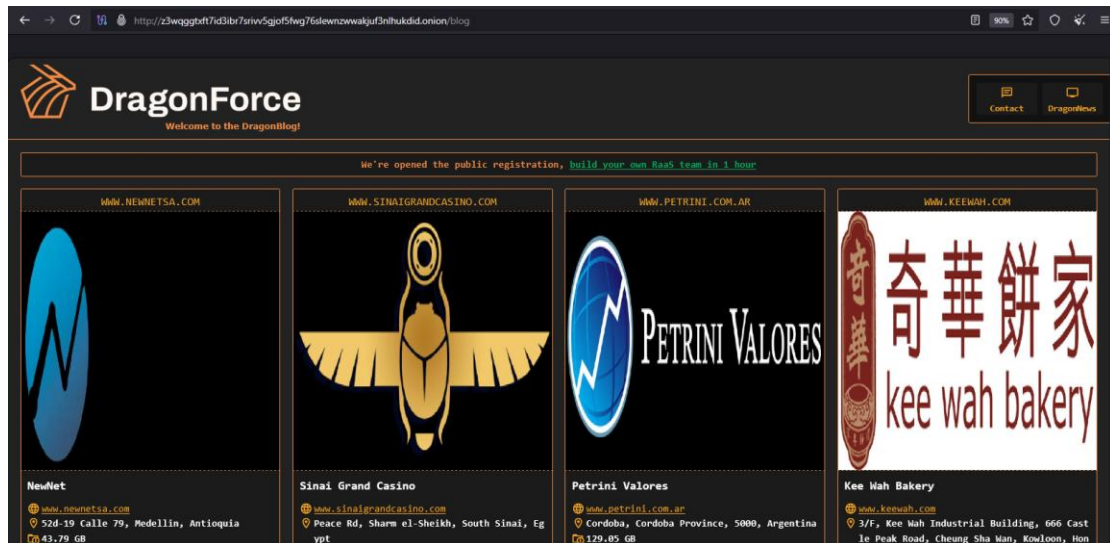
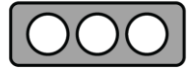
Blog: [http://\[redacted\].onion](http://[redacted].onion)

Sincerely, 01000100 01100010 01100001 01100111 01101110 01101110 01000110 01101111 01110010 01100011 01100101

ภาพเนื้อหาไฟล์เรียกค่าไถ่



ภาพหน้าจอเครื่องเหยื่อที่ถูกเปลี่ยนภาพพื้นหลัง



ภาพ Data leaks site ของกลุ่ม DragonForce

DragonForce Ransomware Arguments

Argument	รายละเอียด
-safe	รีบูตเข้า Safe Mode ก่อนเข้ารหัส (หลบเลี่ยง EDR/AV ที่ไม่ทำงานใน safe mode)
-wall	เปลี่ยนภาพพื้นหลังของระบบและพิมพ์ Ransom note ออกทางเครื่องพิมพ์ จากนั้นลบตัวเองหลังจากเปลี่ยนชื่อครบ 26 ครั้ง
-path	เข้ารหัสเจาะจงไฟล์/โฟลเดอร์ที่ระบุ
-gspd	แก้ไข Group Policy เพื่อใช้กระจายตัวไปเครื่องอื่น (lateral movement)
-psex	กระจายตัวผ่าน admin shares
-gdel	ลบการอัปเดต group policy ที่สร้างไว้
-del	ลบตัวเองหลังเปลี่ยนชื่อไฟล์ 26 ครั้ง



Tactics, Techniques, and Procedures (MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Initial Access	T1190	Exploit Public-Facing Application
Credential Access	T1212	Exploitation for Credential Access
	T1003	OS Credential Dumping
Lateral Movement	T1563.002	Remote Service Session Hijacking (RDP/Citrix session)
	T1021.002	Remote Services: SMB/Windows Admin Shares
	T1021.001	Remote Services: RDP
Privilege Escalation	T1574.011	Hijack Execution Flow: Services Registry Permissions Weakness
Execution	T1569.002	System Services: Service Execution
Persistence	T1136.001	Create Account: Local Account
Defense Evasion	T1070	Indicator Removal
	T1112	Modify Registry
	T1036	Masquerading
Discovery	T1033	System Owner/User Discovery
	T1082	System Information Discovery
Command and Control	T1105	Ingress Tool Transfer
	T1219	Remote Access Software



Tactic	Technique ID	Technique Name
Exfiltration	T1567	Exfiltration Over Web Service
Impact	T1490	Inhibit System Recovery
	T1486	Data Encrypted for Impact



Indicators of Compromise (IoCs)

Indicators of Compromise (IoCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IoCs ผ่านทางแพลตฟอร์ม MISIP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

ร่องรอยที่สามารถตรวจสอบได้:

ค่า IoCs	ประเภทของ IoC
hxxp://z3wqggtxft7id3ibr7srivv5gjof5fwg76slewnzwwakjuf3nlhukdid[.]onion/blog	Threat actor's Data leaks site
dragongoztkdfmnd7jkchznd3fvkpdme4vhbt6p3usrlsoy5dw2bhyd[.]onion	DragonForce Affiliate Registration site
DBKPVG2A5PJEIFCCJRCAO2R2WRX75NJXL3O67U2W5DPCQIMAYJMA	Registration site Authentication key
1C054B722BCBF41A918EF3C485712742088F5C3E81B2FDD91ADEA6BA55F4A856D90A65E99D20	TOX ID
178.16.55[.]7	Attacker IP
-----BEGIN PGP PUBLIC KEY BLOCK----- mDMEZvA84RYJKwYBBAHaRw8BAQdAsfX Dmdq7TYoRcZC61QHEwmZTmy1juaFoQ pjV /j4VFG20C2RyYWdvbmZvcnNliJkEEXYKA EEWIQT/ch8+XeK390StdyKtAdgqXf+F mAUCZvA84QIbAwUJBaPGzwULCQgHAgli AgYVCgkICwIEFglDAQleBwIXgAAKCRCT aDgqXf+FmOCIAQDT18f6LK2lefdcCorWij KPU19ohMBXdDsgE/7dQCedOgEAouaH	Threat actor PGP Public key



odmKN4qS1QobGsDD4VAmXqUORYzFgO 2DyR0qdwI4OARm8DzhEgorBgEEAZdVAQ UB AQdAnIA/YNPyi6VUX7qkr8vMO1OTLL3Q LaegBsaTiTBURhQDAQgHiH4EGBYKACYW IQT/ch8+XeK390StdYKTaDgqXf+FmAUCZ vA84QIbDAUJBaPGzwAKCRCTaDgqXf+F mIHCAQDYjpQuVrBRnMaUGewM6/nBucG GFeCuDMu4GYi9C18igAD+O6dh+kTKgLct 4voWq+COBJ0TJVPg74sb4BwtKOQqgg= =Fau/ -----END PGP PUBLIC KEY BLOCK-----	
ctxsvc	Adversary Account
CtxAppVCOMService	Adversary Account
test	Adversary Account
WIN-4E0AP4JTJR9	Adversary Hostname
WIN-VI960VQI4I6	Adversary Hostname
eng.exe, legal.exe, exsym.exe, as.exe, exp6.exe	LPE Tooling Names
Us.msi, SC.msi	ScreenConnect Installers
za.msi	Zoho Assist Installer
asas.zip, ex.zip, *_update.zip	Password-protected archives from temp[.]sh
1.exe	Dragonforce Ransomware
c84739655ce1af0a0269138263d4756741 8f69e0f75e249f8e23bc21802209e2	LPE SHA256
eb083365dc70d0294e8c4f55a2e78be0e db0f3497f2a06a70c9f474dafab48d8	LPE SHA256
c4fcae3847946173bf0b3cedf5d97a9e3d 18090023842f942ba544fa7fda180d	DragonForce ransomware SHA256



cmd.exe /c sc start AppMgmt >nul 2>nul	LPE Command Line Emission
cmd.exe /c gpupdate /force >nul 2>nul	LPE Command Line Emission
relay.dltsolutions[.]top	ScreenConnect Relay
relay.eurofin[.]digital	ScreenConnect Relay
vtps[.]us	ScreenConnect Relay
opa[.]tlsd[.]shop	Netbird Relay



แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

- ระดับ NetScaler Appliance
 - ตรวจสอบ ns.log หา AAA LOGIN_FAILED ที่ค่า User field เป็นอักขระที่พิมพ์ไม่ได้ (binary/non-printable) นี่คือนิพจน์ที่แสดงให้เห็นการโจมตีจริงที่แท้จริง ไม่ใช่จำนวน failed login ที่สูงเพียงอย่างเดียว
 - ตรวจสอบ session ที่มีอยู่โดยไม่มี login event ที่คู่กัน ซึ่งเป็นสัญญาณของ token replay
 - Correlate IP ต้นทาง login ปกติของผู้ใช้ กับ IP ที่ใช้งาน session เดียวกันในเวลาต่อมา หาก IP เปลี่ยนกะทันหันโดยไม่มี re-authentication ถือเป็นสัญญาณเตือน
 - ส่ง NetScaler log เข้า SIEM ทันที เนื่องจาก ns.log มีการหมุนเวียนที่เร็วมาก หลักฐานอาจหายไปภายในระยะเวลาไม่นาน
- ระดับ Endpoint / Active Directory
 - ตรวจสอบ Event ID 4720 (สร้างบัญชีใหม่) และ 4732 (เพิ่มเข้ากลุ่ม Administrators) ที่เกิดใกล้เคียงกับการรัน sc start AppMgmt หรือ gpupdate /force
 - Monitor การสร้าง REG_LINK / SymbolicLinkValue ใต้ device-class key ของ registry (โดยเฉพาะที่เชื่อมโยงกับ RdpBus GUID)
 - ตรวจสอบ process ที่เปลี่ยนบริบทจาก user ทั่วไปไปเป็น NT AUTHORITY\SYSTEM แบบฉับพลันจาก binary ตัวเดียวกัน
 - Audit หาบัญชีที่ซื้อคล้ายบริการ Citrix แต่ไม่ใช่บัญชีจริง เช่น ctxsvc, CtxAppVCOMService, test
 - ตรวจสอบ instance ของ ScreenConnect, Zoho Assist, Netbird ที่ไม่ได้รับอนุมัติ โดยเทียบ relay host/instance ID กับรายการที่องค์กรอนุมัติไว้
- การเฝ้าระวังการดำเนินการก่อนการเข้ารหัส
 - เฝ้าระวังการใช้คำสั่งลบ shadow copy / backup แบบต่อเนื่อง ในช่วงเวลาสั้น ๆ เช่น vssadmin delete shadows, wbadmin delete



systemstatebackup, bcdedit /set {default} recoveryenabled No, wmic delete catalog

- การใช้ PsExec ด้วย flag -s, การรัน Mimikatz/LaZagne จากไคเรททอรีผิดปกติ (เช่น C:\Binaries)
- การปรากฏของ Impacket/RemCom-based binary ที่ยิงใส่ Domain Controller

หากพบสัญญาณเหล่านี้ ให้ถือว่า **ใกล้ถึงขั้นตอนเข้ารหัสแล้ว** ต้องยกระดับเหตุการณ์เป็น Incident ระดับวิกฤตทันที ไม่รอสัญญาณอื่นเพิ่ม

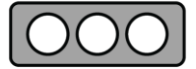
การป้องกัน (Prevention)

- แพตช์ Citrix NetScaler ADC/Gateway ให้เป็นเวอร์ชันล่าสุดที่แก้ไข CVE-2025-5777 โดยทันที และตรวจสอบเวอร์ชันเป็นประจำ
- จำกัดพื้นผิวการโจมตี (attack surface) ของ Appliance ที่เปิดสู่อินเทอร์เน็ต เช่น จำกัด IP ที่เข้าถึงได้ (allowlist) หากทำได้ตามลักษณะการใช้งาน
- Terminate session ที่ค้างอยู่ทั้งหมดหลังแพตช์ Session token ที่ถูกขโมยไว้ก่อนแพตช์ ยังคงใช้งานได้ต่อแม้ปิดช่องโหว่แล้ว
- ให้สิทธิ์ Admin เฉพาะเท่าที่จำเป็นต่อบทบาทงาน (least privilege) ลดผลกระทบหาก Session ถูกขโมย
- บังคับใช้ MFA และเสริมด้วยการผูก session เข้ากับปัจจัยอื่น เช่น IP หรือ Device fingerprint หากอุปกรณ์รองรับ
- จำกัดการใช้งาน AppMgmt service หากไม่จำเป็นต้องใช้ software deployment ผ่าน GPO ในบางสภาพแวดล้อม
- จัดทำ allowlist ซอฟต์แวร์ที่อนุญาตให้รันได้ (application allow list) เพื่อสกัด unsigned dropper ที่ดาวน์โหลดมาจาก temp[.]sh หรือแหล่งคล้ายกัน
- ควบคุมและตรวจสอบการติดตั้ง RMM tool (ScreenConnect, Zoho Assist ฯลฯ) ให้อยู่ภายใต้กระบวนการอนุมัติ ไม่ปล่อยให้ผู้ใช้ทั่วไปติดตั้งเองได้
- ใช้ **backup แบบ offline หรือ immutable** ที่แยกออกจากเครือข่ายหลักโดยสมบูรณ์ เนื่องจาก DragonForce ทำลาย shadow copy, system state backup และปิด boot recovery ก่อนเข้ารหัสเสมอ ไม่สามารถพึ่งพากลไกกู้คืนใน Windows เพียงอย่างเดียว และทดสอบการกู้คืนจาก backup เป็นระยะเพื่อยืนยันว่าใช้งานได้จริงเมื่อเกิดเหตุ



การรับมือ (Response)

- การรับมือทันทีที่มีสัญญาณการบุกรุก
 - หากตรวจโฮสต์ที่มีสัญญาณต้องสงสัย (บัญชีแปลกปลอม, RMM ที่ไม่รู้จัก, กิจกรรม LPE) ให้แยกออกจากเครือข่ายทันที ก่อนที่จะลุกลามไปสู่ Domain-wide
 - Terminate session ทั้งหมด บน NetScaler ที่ได้รับผลกระทบ โดยเฉพาะ session ที่มีพฤติกรรมผิดปกติ
 - แจ้ง incident response team และเริ่มกระบวนการ containment ตาม playbook ขององค์กรทันที เนื่องจากในบางเคสใช้เวลาไม่ถึง 1 ชั่วโมง จาก initial access ถึงการเข้ารหัส
- การสืบสวนและเก็บหลักฐาน
 - ดำเนินการเก็บ ns.log, Windows Event log, และ registry snapshot ก่อนที่ระบบจะถูก reboot หรือ log จะหมุนทับ
 - ตรวจสอบว่ามีบัญชี admin ปลอมถูกสร้างขึ้นไว้หรือไม่ (ctxsvc, CtxAppVCOMService, test หรือชื่ออื่นที่ผิดปกติ) และปิดใช้งานทันทีที่พบ
 - ตรวจสอบว่ามี RMM tool ที่ไม่ได้รับอนุมัติติดตั้งอยู่หรือไม่ (ScreenConnect, Zoho Assist, Netbird) และถอนการติดตั้งพร้อมบล็อก relay/infrastructure ที่เกี่ยวข้อง
 - ตรวจสอบ Domain Controller ว่ามีร่องรอย Impacket, RemCom หรือการ dump credential (Mimikatz, LaZagne) หรือไม่ หากพบ ให้พิจารณา reset krbtgt และรหัสผ่านบัญชีที่มีสิทธิ์สูงทั้งหมด
- การรับมือในกรณีที่เกิดการเข้ารหัสแล้ว
 - ตัดการเชื่อมต่อเครือข่ายของโฮสต์ที่ถูกเข้ารหัสทันที เพื่อจำกัดการแพร่กระจายไปยังไฟล์ share หรือเครื่องอื่น
 - ห้าม reboot เครื่องที่ถูกเข้ารหัสโดยไม่จำเป็น เพราะอาจกระตุ้น argument เช่น -safe ที่ทำให้เข้ารหัสเพิ่มเติมใน safe mode
 - ตรวจสอบว่ามี exfiltrate ข้อมูลออกไปก่อนเข้ารหัสหรือไม่ (double extortion) เนื่องจาก DragonForce มักขโมยข้อมูลผ่าน MEGA.nz, FTP/SFTP



หรือ HTTP server ก่อนเข้ารหัสเสมอ ควรตรวจ log การส่งข้อมูลออกนอกองค์กร
ในช่วงเวลาก่อนพบเหตุ

- การกู้คืนระบบ
 - กู้คืนจาก backup แบบ offline/immutable ที่ยืนยันแล้วว่าไม่ถูกระทบ
 - แพตช์ช่องโหว่ต้นเหตุ (NetScaler) ให้เรียบร้อยก่อนนำระบบกลับเข้าสู่การใช้งานเพื่อป้องกันการเข้าถึงซ้ำ
 - เปลี่ยนรหัสผ่านทุกบัญชีที่อาจถูกขโมย credential รวมถึงบัญชีที่เคย login ผ่านช่วงเวลาที่มีการโจมตี



อ้างอิง (References)

1. Huntress's Blog "Seven Steps to Ransomware: CitrixBleed 2 Weaponized by Initial Access Brokers"
<https://www.huntress.com/blog/citrixbleed-2-dragonforce-ransomware>
2. TrendAI's Research "Ransomware Spotlight: DragonForce"
<https://www.trendaisecurity.com/en/resources-insights/research/ransomware-spotlight-dragonforce>
3. ANALYST1's Threat Actor Blog "DragonForce"
<https://analyst1.com/threat-actors/dragonforce/>
4. Acronis's Article "The DragonForce Cartel: Scattered Spider at the gate"
<https://www.acronis.com/en/tru/posts/the-dragonforce-cartel-scattered-spider-at-the-gate/>
5. NIST CVE Detail "CVE-2025-5777"
<https://nvd.nist.gov/vuln/detail/cve-2025-5777>



แบบประเมินรายงานข่าวกรองไซเบอร์

<https://dg.th/nsexlfob51>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th